

Security+ 2.4 · Viruses & Worms

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.4** —
Viruses & Worms (5:54) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Viruses require a host file and user action to propagate. Worms self-propagate across the network without a host or user action. Fileless malware runs directly in RAM and does not touch disk. Defense: patching (worms exploit network vulnerabilities) and EDR with behavioral detection.

High-Yield Core Concepts Tested on Exam

- Virus: requires host + user action. Worm: self-propagates without user action
- Fileless: no file on disk—detected via memory/logs, not hash
- Worms exploit network vulnerabilities to spread rapidly
- Patching is critical to prevent worm propagation
- EDR with behavioral detection can identify fileless and worm activity
- Viruses often spread via email attachments or infected files

Exam Tips & Classic Scenarios

- 'self-propagates through the network without user action' = worm
- 'requires a host file' = virus
- 'spreads without any click' = worm

Typical Exam Scenario: Malware spreads across the network without any user interaction, exploiting a vulnerability. This is a worm.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.4 — Viruses & Worms)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **WORM:** Write Once, Read Many: Immutable optical/cloud storage paradigm preventing data alteration or deletion during retention periods (critical for audit logs).

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Which type of malware spreads automatically across networks without the need for a host file or user interaction?

- A) Worm
- B) Trojan
- C) Spyware
- D) Adware

2. Malware that encrypts your files and demands payment to return them is:

- A) Spyware
- B) Ransomware
- C) Rootkit
- D) Worm

3. Corporate scenario (Viruses & Worms): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Virus: requires a host + user. Worm: self-propagates'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Virus: requires a host + user. Worm: self-propagates...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Viruses & Worms): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Fileless: no file on disk — detected by memory/log, not hash'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Fileless: no file on disk — detected by memory/log, not hash...
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Viruses & Worms): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'self-propagates through the network without user action' = worm'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'self-propagates through the network without user action' = worm...
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Viruses & Worms): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: malware spreads across the network without any click = worm.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Scenario: malware spreads across the network without any click = worm...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Viruses & Worms): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Virus: requires a host + user. Worm: self-propagates'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Virus: requires a host + user. Worm: self-propagates...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Viruses & Worms): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Fileless: no file on disk — detected via memory/logs, not hash.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Fileless: no file on disk — detected via memory/logs, not hash...

9. Corporate scenario (Viruses & Worms): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'self-propagates through the network without user action' = worm. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'self-propagates through the network without user action' = worm
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Viruses & Worms): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.4), an analyst evaluates the following technical requirement: 'Scenario: 'malware spreads across the network without any click' = worm.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: 'malware spreads across the network without any click' = worm....
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Worm.

✓ **Why it's correct:** A Worm is a type of standalone malware that self-replicates and spreads automatically across networks, exploiting vulnerabilities in services or operating systems, without the need for a host file or user interaction. Unlike viruses, it does not need a carrier program to propagate. In CompTIA Security+ (domain 2.4 - 'Given a scenario, analyze indicators of malicious activity'), a worm is classically defined as malware that spreads on its own across the network, consuming bandwidth and compromising systems at scale. This is exactly what the question describes.

✗ **Why the others are wrong:**

- *Trojan:* A Trojan is malware that disguises itself as legitimate software to trick the user into executing it. It depends on user interaction to infect the system and does not self-replicate automatically across the network. Therefore, it does not meet the criterion of 'spreading automatically without user interaction'.
- *Spyware:* Spyware is malicious software designed to collect user information without consent, such as browsing habits, credentials, and personal data. It does not spread automatically across networks; it is typically installed through social engineering or bundled with other software. Thus, it is not the correct answer.
- *Adware:* Adware is software that displays unwanted advertisements and may redirect the browser, but it does not self-replicate or spread automatically across networks. Its dissemination depends on user installation or other malware. Therefore, it does not meet the question's criteria.

2) B — Ransomware.

✓ **Why it is correct:** The correct answer is 'Ransomware'. Ransomware is a type of malware that encrypts the victim's files and demands a ransom payment (usually in cryptocurrency) to provide the decryption key. The statement describes exactly this behavior: malware that encrypts files and demands payment to return them. CompTIA classifies ransomware as a critical threat, often propagated through phishing, vulnerability exploitation, or remote desktop services. Therefore, the option 'Ransomware' is the precise definition of the described attack.

✗ **Why the other options are wrong:**

- *Spyware:* Spyware is malicious software designed to collect information from the infected system without the user's consent, such as browsing habits, credentials, banking data, etc. It does not encrypt files or demand ransom. Its primary function is to spy and exfiltrate data. In the scenario, the goal is to extort money through file encryption, which is not a characteristic of spyware. Therefore, spyware does not apply.
- *Rootkit:* A rootkit is a set of malicious tools that allows an attacker to gain privileged access (root) and maintain persistence on the system, hiding its presence from detection mechanisms. Although it can be used in conjunction with ransomware, a rootkit itself does not encrypt files or demand payment. Its purpose is stealth, not extortion. The statement describes a financial extortion attack via encryption, not the installation of a rootkit. Thus, rootkit is not the correct answer.
- *Worm:* A worm is self-replicating malware that spreads automatically across the network, exploiting vulnerabilities, without necessarily needing a host file or user interaction. Although worms can carry payloads like ransomware, they are not defined by encrypting files and demanding ransom. The behavior described in the statement is specific to ransomware, not a worm. Therefore, worm is an incorrect classification for the attack in question.

3) B — Implement the corresponding solution: Virus: requires a host + user. Worm: self-propagates....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Viruses & Worms): Virus: requires a host + user. Worm: self-propagates. A virus needs a host file and user action to spread, while a worm can self-replicate and spread across networks without user intervention, making it more dangerous.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) C — Implement the corresponding solution: Fileless: no file on disk — detected by memory/log, not hash....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Viruses & Worms): Fileless: no file on disk — detected by memory/log, not hash. Fileless malware resides in memory and uses legitimate system tools, evading traditional hash-based detection. Detection requires memory analysis, behavioral monitoring, and log correlation.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: 'self-propagates through the network without user action' = worm....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Viruses & Worms): 'self-propagates through the network without user action' = worm.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: Scenario: malware spreads across the network without any click = worm....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Viruses & Worms): Scenario: malware spreads across the network without any click = worm. A worm is self-replicating malware that propagates across networks autonomously, exploiting vulnerabilities without requiring user interaction, unlike a virus which typically needs a host file and user action.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Virus: requires a host + user. Worm: self-propagates....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Viruses & Worms): Virus: requires a host + user. Worm: self-propagates.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: Fileless: no file on disk — detected via memory/logs, not hash....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Viruses & Worms): Fileless: no file on disk — detected via memory/logs, not hash. Fileless malware resides in memory (e.g., PowerShell, WMI, registry) and evades traditional hash-based detection. It requires memory analysis, behavioral monitoring, and logging to detect.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: 'self-propagates through the network without user action' = worm.

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Viruses & Worms): 'self-propagates through the network without user action' = worm. A worm is a standalone malware that replicates itself to spread to other computers, often exploiting network vulnerabilities without requiring user interaction.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Scenario: 'malware spreads across the network without any click' = worm.....

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.4 (Viruses & Worms): Scenario: 'malware spreads across the network without any click' = worm. This correctly identifies a worm as self-replicating malware that spreads autonomously across networks without requiring user interaction, unlike viruses which typically require a host file or user action.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.